

SSO Application – Backend Design

Oct 9, 2026 · @Anubhav

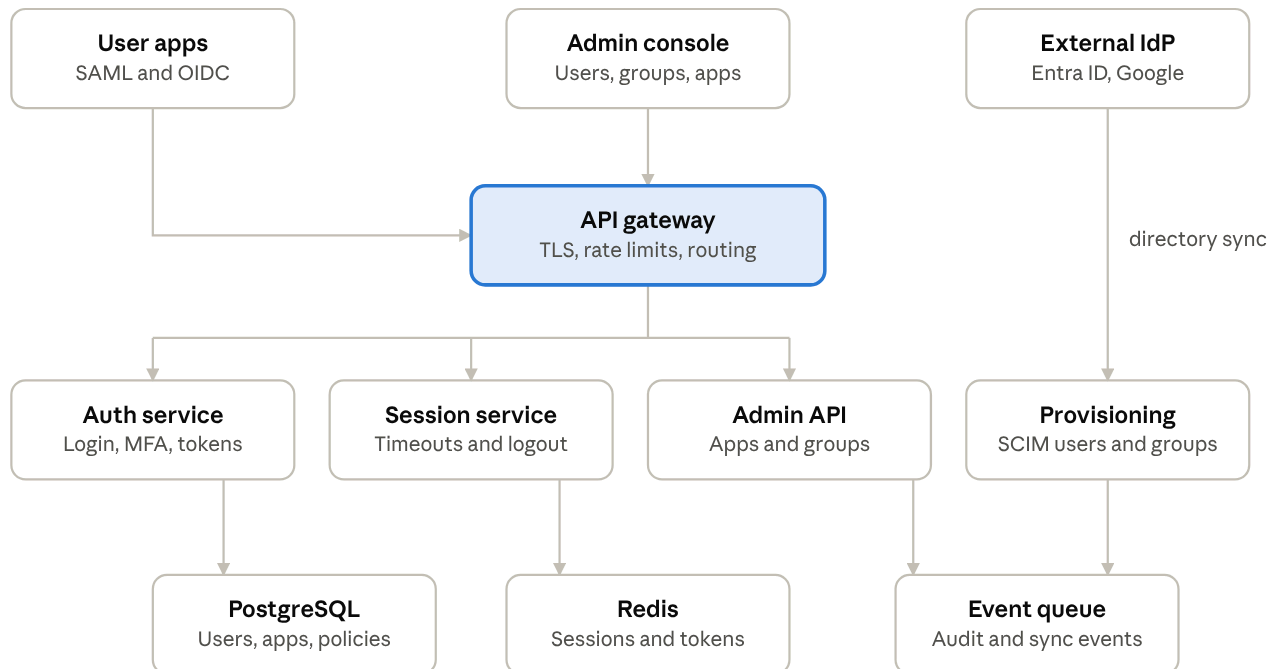
Overview

The backend implements the PRD for v1: one login through an identity provider, SAML 2.0 and OIDC for app sign-on, SCIM 2.0 provisioning, MFA, session management, an admin API, and audit logging. Target scale is 100,000 users and 500 applications per tenant, with 99.9% availability.

The design uses a small set of services behind one gateway, a relational database as the source of truth, and an event queue for provisioning and audit. It is deliberately a modular monolith split into deployable services only where load or failure isolation requires it, which keeps v1 operable by a small team.

Architecture

Every sign-in passes the gateway while provisioning runs on its own path



services and what calls what

Every request enters through the API gateway. Provisioning reads directory changes and publishes them to the event queue.

Services

Service	Owns	Calls	Scales with
API gateway	TLS termination, routing, rate limits, request IDs	Auth, Session, Admin API	Requests per second
Auth service	Federation (SAML, OIDC), MFA, token issuance and signing keys	PostgreSQL, Redis, external IdPs	Sign-in volume
Session service	Session records, idle and absolute timeouts, single logout	Redis, PostgreSQL	Active sessions
Admin API	Applications, groups, policies, admin roles	PostgreSQL, Event queue	Admin traffic (low)
Provisioning worker	SCIM 2.0 endpoints, directory sync jobs	PostgreSQL, Event queue, downstream apps	Number of users and apps
Audit writer	Consumes events, writes the audit log, serves CSV export	Event queue, PostgreSQL	Event volume

All services are deployed from one repository as separate processes so they can scale independently. The Auth and Session services are the only ones on the sign-in path, which keeps their latency budget small.

Authentication flows

OIDC sign-in (web and mobile apps)

1. The app redirects the user to the Auth service's authorize endpoint with a PKCE code challenge.
2. The Auth service checks the session. If none exists, it shows the login page and runs MFA.

3. The Auth service returns a short-lived authorization code to the app's redirect URI.
4. The app exchanges the code plus the PKCE verifier for an ID token and an access token.
5. Tokens are signed with ES256. Refresh tokens rotate on each use.

SAML 2.0 sign-on (enterprise apps)

1. The app sends an AuthnRequest, or the user starts from the portal (IdP-initiated).
2. The Auth service validates the request against the app's registered metadata.
3. After login, it returns a signed SAML Response to the app's assertion consumer URL.
4. Assertions expire in 5 minutes and are single-use; replays are rejected.

Federated login

When the user's home directory is an external IdP, the Auth service redirects to that IdP and receives its assertion, then issues its own session and tokens. The user never signs in to the app directly against the IdP.

Data model

Table	Key columns	Notes
tenants	id, name, created_at	One row per customer organization
users	id, tenant_id, external_id, email, status	Unique on (tenant_id, email); status: active, suspended, deprovisioned
groups	id, tenant_id, name, source	source: directory or manual
group_memberships	group_id, user_id	Composite primary key
applications	id, tenant_id, protocol, status, config	protocol: saml or oidc; config holds metadata and redirect URIs as JSON
app_assignments	application_id, principal_type, principal_id	principal is a user or a group
mfa_factors	id, user_id, type, secret_ref, created_at	Secrets live in a KMS-backed vault, not in this table

Table	Key columns	Notes
sessions	id, user_id, created_at, last_seen_at, expires_at, revoked_at	Mirrored to Redis for fast lookup
signing_keys	id, tenant_id, algorithm, public_key, private_key_ref, active_from, retired_at	Rotated every 90 days
audit_events	id, tenant_id, actor, action, target, occurred_at, payload	Append-only; retained 365 days; partitioned by month
sync_cursors	tenant_id, source, last_token	Directory sync resume point

Every tenant-scoped table carries `tenant_id`, and queries are scoped by it in the data access layer. Row-level security in PostgreSQL is a second barrier.

API surface

Method and path	Service	Purpose
GET /oauth2/authorize	Auth	OIDC authorization endpoint
POST /oauth2/token	Auth	Code exchange and refresh
GET /oauth2/userinfo	Auth	Claims for the signed-in user
POST /saml/sso	Auth	SAML AuthnRequest and login
GET /.well-known/openid-configuration	Auth	OIDC discovery document
POST /session/logout	Session	Single logout across apps
GET /v1/apps	Admin API	List applications
POST /v1/apps	Admin API	Register a SAML or OIDC application
PATCH /v1/apps/{id}	Admin API	Update config or status
PUT /v1/apps/{id}/assignments	Admin API	Set users and groups with access
GET /v1/users	Admin API	Search and list users

Method and path	Service	Purpose
GET /v1/audit-events	Admin API	Query audit log; format=csv for export
POST /scim/v2/Users	Provisioning	SCIM create user
PATCH /scim/v2/Users/{id}	Provisioning	SCIM update or deactivate
GET /scim/v2/Groups	Provisioning	SCIM list groups

All /v1 endpoints take a bearer token with an admin scope. Errors use RFC 7807 problem details. Lists are cursor-paginated with a maximum page size of 200.

Tech stack and infrastructure

Layer	Choice	Reason
Language and runtime	TypeScript on Node.js 22 LTS	Mature SAML and OIDC libraries; one language for services and workers
Framework	Fastify	Low overhead on the sign-in path
Database	PostgreSQL 16 (managed)	Relational integrity, row-level security, mature tooling
Cache and session store	Redis (managed)	Sub-millisecond session lookups
Event queue	Managed Kafka or a managed queue with ordering per tenant	Durable audit and sync events
Secrets and keys	Cloud KMS plus a secrets manager	Keys never stored in the database
Hosting	Kubernetes on one cloud region, with a second region for disaster recovery	Horizontal scaling and standard tooling
Infrastructure as code	Terraform	Reproducible environments

Layer	Choice	Reason
CI/CD	Build, test, and deploy pipeline with staged rollout	Safe releases of auth-critical code

Two regions: primary active, secondary warm standby, which meets the 15-minute RPO and 1-hour RTO in the PRD through asynchronous replication.

Security, scalability and observability

Security

- Signing keys are RS256 or ES256, stored in KMS, and rotated every 90 days with a 14-day overlap for verification.
- Passwords are hashed with Argon2id. MFA secrets are encrypted at rest.
- Login and token endpoints are rate-limited per IP and per account; repeated failures trigger lockout with backoff.
- Admin actions require step-up MFA and are written to the audit log before the response returns.
- Redirect URIs and SAML audiences are matched exactly against registered values.

Scalability

- Auth and Session services are stateless and scale horizontally behind the gateway.
- Session lookups hit Redis first; PostgreSQL is the fallback.
- Directory sync runs per tenant so one large tenant cannot delay others.
- Capacity target: 100,000 users and 500 applications per tenant, with headroom to 3x.

Observability

- Structured logs with tenant ID and request ID on every line.
- Metrics: sign-in success rate, p95 redirect latency, token issuance errors, sync lag per tenant.
- Alerts when sign-in success rate drops below 99.5% for 5 minutes, and when sync lag exceeds 5 minutes.
- Distributed traces across gateway, Auth, and Session.

Open questions and decisions needed

- ☒ ~~Confirm the directory list for v1 (Entra ID and Google Workspace only, or also Okta and LDAP?).~~
- ☒ ~~Decide between managed Kafka and a managed queue for the event bus; cost and ordering guarantees differ.~~
- ☐ Confirm the hosting cloud and region, which sets the KMS and managed-service choices.
- ☒ ~~Decide whether the audit log needs tamper evidence (hash chaining) for compliance.~~
- ☒ ~~Confirm whether customers, not only workforce users, will sign in, since that changes tenant and billing models.~~
- ☒ ~~Choose a SCIM conformance test suite and the list of target applications for certification.~~